GUIDE DE DÉPLOIEMENT

Entra ID P1

Minimum Viable de Conformité (MVC)

PME suisse 5 à 25 personnes, Microsoft 365 Business Premium

Licence :	Microsoft 365 Business Premium (Entra ID P1 inclus)
Tenant :	[tenant].onmicrosoft.com (à remplacer)
Client :	[Nom du client] (à remplacer)
Durée :	2 à 3 heures (déploiement + tests)
Prérequis :	MVC Purview déployé (ou au minimum Audit actif)
Version :	3.5, novembre 2026

Table des matières

Préface
Partie 0 : Prérequis
Partie 1 : Méthodes d'authentification
Partie 2 : Emplacements nommés
Partie 3 : CA-01, MFA pour tous les utilisateurs
Partie 4 : CA-02, Blocage de l'authentification héritée
Partie 5 : CA-03, Filtrage géographique
Partie 6 : CA-04, Token Protection
Partie 7 : CA-05, Session limitée sur appareils non gérés
Partie 8 : CA-06, Connexions hors horaires, expérimental
Partie 9 : CA-08, Exiger un appareil conforme
Partie 10 : SSPR, Réinitialisation du mot de passe
Partie 11 : Tests et validation
Checklist de remise client
Annexe A : Glossaire
Annexe B : Checklist MVC complète avec références nLPD
Annexe C : Références nLPD, mesures techniques couvertes
Annexe D : Tableau récapitulatif des politiques CA
Annexe E : Adaptations sectorielles
Annexe F : Différences POC et production

ATTENTION remplacez `[tenant]` et `[Nom du client]` par les informations réelles du client avant toute utilisation.

Préface

INFO ce guide est un guide nLPD (nouvelle Loi fédérale sur la Protection des Données, Suisse, RS 235.1). Délai de notification d'une violation : « dès que possible », pas de délai fixe de 72 heures comme dans le RGPD européen. Autorité compétente : PFPDT, pas la CNIL.

Ce guide déploie la couche **identité et accès** du bundle MVC nLPD. Il est découpé en deux temps dans le déploiement du bundle :

- **Étape 0, avant Purview (Parties 0 à 3)** : prérequis, comptes break-glass, méthodes d'authentification, emplacements nommés, MFA pour tous (CA-01) et MFA anti-hameçonnage pour les administrateurs (CA-09). Environ 1 h 30 à 2 h de travail technique.
- **Suite, après Purview (Parties 4 à 10)** : CA-02 à CA-08 et SSPR, avant ou en parallèle du guide Intune + Defender.

INFO **durée.** Les durées indiquées sont du temps de travail technique. Les périodes en mode Rapport (7 à 14 jours selon la politique) sont du temps calendaire : prévoyez-les dans le planning du client.

La nLPD art. 8 exige des mesures techniques de protection adaptées au risque. Le contrôle des identités est la première de ces mesures : un mot de passe volé contourne tous les autres contrôles.

Pilier	Ce que ça apporte
Deux comptes break-glass	Accès de secours exclu de toutes les politiques CA : évite le verrouillage total du tenant
Emplacements nommés	Définit la zone géographique légitime pour les règles de filtrage `[nLPD art. 8]`
MFA obligatoire (CA-01)	Première barrière contre la compromission de compte `[nLPD art. 8]`
MFA anti-hameçonnage admins (CA-09)	Protège les comptes à privilèges avec une méthode résistante au hameçonnage `[nLPD art. 8]`
Blocage auth. héritée (CA-02)	Ferme le contournement du MFA via IMAP, POP3, SMTP, EAS `[nLPD art. 8]`
Filtrage géographique (CA-03)	Applique les restrictions géographiques définies par l'entreprise sur les connexions couvertes `[nLPD art. 8]`
Token Protection (CA-04)	Réduit le risque de rejeu de jetons de session sur les plateformes et applications compatibles `[nLPD art. 8]`
Session limitée (CA-05)	Restreint les sessions sur appareils non gérés `[nLPD art. 8]`
Hors horaires (CA-06, expérimental)	Signale les connexions hors heures ouvrables, mesure complémentaire optionnelle `[nLPD art. 8]`
Appareil conforme (CA-08)	Exige un appareil conforme Intune, en mode Rapport puis Application `[nLPD art. 8]`
SSPR	Réinitialisation autonome et auditée des mots de passe `[nLPD art. 8]`

INFO ce guide est strictement limité à Entra ID P1, inclus dans Microsoft 365 Business Premium. Les fonctionnalités Entra ID P2 (Identity Protection, PIM, Access Reviews) sont hors périmètre MVC : elles exigent un add-on de licence supplémentaire (Defender Suite).

INFO **vocabulaire du portail.** Dans le formulaire d'une stratégie, l'état « Application » de ce guide correspond au réglage **Activé** de « Activer une stratégie » (les autres choix sont « Rapport uniquement » et « Désactivé »). Les contrôles se règlent sous « Contrôles d'accès » : **Octroyer** (accorder ou bloquer) et **Session**.

INFO **dates et statuts vérifiés le 6 novembre 2026** sur la documentation et le centre de messages Microsoft. Les calendriers Microsoft évoluent : revérifiez les dates marquées « 2026 » avant chaque déploiement.

INFO il n'existe pas de politique CA-07 dans le MVC. La numérotation CA-01 à CA-06, CA-08 puis CA-09 est conservée pour rester identique dans tous les guides du bundle (le nom `CA-08` est référencé dans le guide Intune + Defender ; CA-09 a été ajoutée sans renuméroter les autres).

Niveaux de déploiement

Niveau	Contenu	Pour qui
Niveau 1, socle	Break-glass, CA-01, CA-09, CA-02, SSPR	Toute PME, à faire en premier
Niveau 2, renforcement	CA-08, CA-05, CA-04, CA-03	Après le guide Intune + Defender pour CA-08 et CA-04 ; selon le contexte du client
Niveau 3, expérimental	CA-06 (hors horaires)	Optionnel, mode Rapport uniquement, à documenter

Partie 0 : Prérequis

0.1 Portail et rôles

N°	Étape	Action
1	Navigateur	Microsoft Edge ou Chrome. Évitez Firefox pour les portails admin.
2	URL	https://entra.microsoft.com
3	Connexion	Compte admin M365 (Administrateur général ou Administrateur de la sécurité).
4	Rôles requis	Administrateur de la sécurité → politiques CA, méthodes d'authentification. Administrateur de l'authentification → SSPR, méthodes, TAP. Administrateur de stratégie d'authentification → Authentication Strength.

ATTENTION après ajout d'un rôle, déconnectez-vous et reconnectez-vous. Les rôles ne prennent pas effet dans la session en cours.

0.2 Deux comptes break-glass

IMPORTANT créez les deux comptes break-glass AVANT d'activer toute politique CA. Sans eux, une mauvaise configuration peut vous bloquer définitivement hors du tenant, sans recours possible. Microsoft recommande deux comptes avec des méthodes d'authentification différentes.

N°	Étape	Action
1	Compte BG-1	entra.microsoft.com → Utilisateurs → Tous les utilisateurs → Nouvel(le) utilisateur(-trice) → Créer un utilisateur (onglet Informations de base : Nom d'utilisateur principal, Domaine, Nom d'affichage, Mot de passe). Nom d'utilisateur principal : `bga1@[tenant].onmicrosoft.com` (en production, utilisez des noms neutres de type humain, par exemple `prenom.nom@[tenant].onmicrosoft.com`, pour masquer la fonction du compte). Domaine : toujours `@[tenant].onmicrosoft.com` (cloud-only). Méthode MFA : FIDO2 (clé physique stockée en coffre). Pas de licence assignée. Mot de passe de 25 caractères ou plus qui n'expire pas (vérifier la politique d'expiration du tenant ; au besoin `Update-MgUser -UserId <UPN> -PasswordPolicies DisablePasswordExpiration`).
2	Compte BG-2	Même principe, nom neutre différent. Méthode MFA : authentification par certificat (CBA) si l'environnement le permet, pour obtenir un mécanisme différent de BG-1. À défaut, une seconde clé FIDO2 indépendante, stockée dans un autre lieu que celle de BG-1 : la redondance est assurée, mais pas la diversité des mécanismes. Éviter les méthodes liées à un téléphone ou à une personne. Mot de passe différent de BG-1.
3	Groupe break-glass	entra.microsoft.com → Groupes → Tous les groupes → Nouveau groupe. Type de groupe : Sécurité. Nom de groupe : `GRP-CA-BreakGlass`. Type d'appartenance : Affecté. Membres : Aucun membre sélectionné (lien) → ajouter bga1 + bga2 → Créer.
4	Rôle	entra.microsoft.com → Rôles et administrateurs → Administrateur général → Ajouter des affectations → bga1 + bga2, affectation **permanente active** (pas d'éligibilité PIM : PIM est hors périmètre P1).
5	Enregistrement MFA	Enregistrer au moins une méthode MFA forte (FIDO2 ou CBA) sur chaque compte break-glass. Connexion test bga1 dans une fenêtre privée → accès au portail Entra ID.
6	Alerte de connexion	Objectif de production : toute connexion d'un compte break-glass déclenche une alerte immédiate (Azure Monitor ou Sentinel si le client a un abonnement Azure, ou règle du SIEM, par exemple UTMStack). Solution dégradée, à documenter avec ses limites : revue mensuelle des journaux de connexion filtrés sur bga1 et bga2. Ce n'est pas une alerte : une connexion malveillante peut passer inaperçue jusqu'à un mois.

ATTENTION **MFA des portails admin.** Microsoft impose le MFA au niveau des portails admin indépendamment des politiques CA : portails Azure, Entra et Intune depuis octobre 2024 ; centre d'administration Microsoft 365 depuis février 2025 (déploiement progressif) ; Azure CLI, Azure PowerShell, API REST, SDK et outils d'infrastructure as code depuis le 1er octobre 2025 (opérations de création, modification et suppression). Les échéances de report sont passées et Microsoft poursuit le déploiement progressif : vérifiez l'état effectif dans le tenant avant le déploiement. Les comptes break-glass restent exclus de toutes les CA, mais ils sont aussi concernés par cette exigence lorsqu'ils accèdent aux portails couverts. C'est pourquoi une méthode MFA compatible (FIDO2 ou CBA) doit être enregistrée : sans elle, le compte break-glass ne peut plus accéder aux portails.

ATTENTION **test trimestriel.** Validez les deux comptes tous les 90 jours et à chaque départ ou changement de rôle d'une personne qui connaît leur emplacement : connexion réussie, méthode MFA fonctionnelle, appartenance au groupe `GRP-CA-BreakGlass` et exclusion de chaque politique CA contrôlées. Les mots de passe n'ont pas à être renouvelés périodiquement, sauf soupçon de compromission ou départ d'un détenteur. Documentez chaque test dans le registre de sécurité.

0.3 Désactiver Security Defaults

ATTENTION Security Defaults et l'accès conditionnel ne peuvent pas coexister. Si Security Defaults est activé, désactivez-le avant de créer des politiques CA. Les deux systèmes en conflit provoquent des comportements imprévisibles.

N°	Étape	Action
1	Accès	entra.microsoft.com → Vue d'ensemble → Propriétés → descendre jusqu'à la section « Paramètres de sécurité par défaut ».
2	Désactiver	Toggle : Désactiver. Motif : Utilisation de l'accès conditionnel (P1).
3	Enregistrer	Cliquez Enregistrer.

INFO si des politiques d'accès conditionnel existent déjà, le portail n'affiche pas l'interrupteur et indique : « Votre organisation utilise actuellement des stratégies d'accès conditionnel qui vous empêchent d'activer les paramètres de sécurité par défaut ». Security Defaults est alors déjà désactivé, rien à faire.

INFO si Security Defaults était actif, les utilisateurs déjà enregistrés en MFA gardent leur enregistrement. Procédez directement à la configuration des politiques CA.

Partie 1 : Méthodes d'authentification

1.1 Activer les méthodes recommandées

Chemin : entra.microsoft.com → Entra ID → Méthodes d'authentification → Stratégies

N°	Étape	Action
1	Microsoft Authenticator	Cliquer → Activer → Tous les utilisateurs → Enregistrer. Méthode privilégiée : passkeys FIDO2 disponibles dans l'app depuis 2026.
2	Clé d'accès (FIDO2)	Cliquer → Activer → Tous les utilisateurs → Autoriser les passkeys liés à l'appareil : Microsoft Authenticator et clés physiques FIDO2 (par exemple YubiKey). Les passkeys synchronisés (iCloud Keychain, Google Password Manager) sont une autre catégorie : ne pas les autoriser pour les administrateurs ; pour les autres utilisateurs, décision à documenter avec le client. Enregistrer.
3	SMS	Optionnel et transitoire : activer seulement si des utilisateurs n'ont pas encore enregistré Authenticator ou une clé d'accès. Le SMS est une méthode plus faible : prévoir sa désactivation une fois l'enregistrement généralisé.
4	Appel vocal	Optionnel. Utile pour les utilisateurs sans smartphone compatible.

INFO **migration des stratégies héritées.** Depuis le 30 septembre 2025, les anciennes stratégies MFA et SSPR sont déconnectées et les paramètres sont gérés par ces stratégies unifiées. La page affiche un bandeau « État de la migration » : terminez la migration (lien « changer ») si elle est « En cours ». Le portail peut aussi annoncer l'activation automatique des clés d'accès pour les utilisateurs qui utilisent le SMS ou l'appel vocal.

ATTENTION **MFA per-user legacy.** Vérifiez qu'aucun utilisateur n'est en statut « Appliqué » (Enforced) dans l'ancienne interface MFA : admin.microsoft.com → Utilisateurs actifs → Authentification multifacteurs. Tous doivent être en « Désactivé ». Les deux systèmes en conflit provoquent des blocages inexpliqués.

1.2 Passe d'accès temporaire (TAP)

Chemin : Entra ID → Méthodes d'authentification → Stratégies → Passe d'accès temporaire (la page de réglages s'intitule « Paramètres Droit d'accès temporaire »)

N°	Étape	Action
1	Activer	Onglet « Activer et cibler » → Activer : interrupteur sur Activé. Cible : Tous les utilisateurs.
2	Durée	Onglet « Configurer » → Modifier. Durée de vie minimale : 1 heure. Durée de vie maximale : 8 heures. Durée de vie par défaut : 1 heure (valeurs par défaut du portail).
3	Usage unique	Onglet « Configurer » → Une seule fois : Oui (recommandé pour l'onboarding). La valeur par défaut est Non. Longueur : 8 caractères (par défaut).
4	Enregistrer	Cliquer Enregistrer.

> **INFO** le TAP est le moyen recommandé pour enregistrer le premier facteur MFA (passkey ou FIDO2) lors de l'onboarding. Émission : entra.microsoft.com → Utilisateurs → [utilisateur] → Méthodes d'authentification → + Ajouter une méthode d'authentification → Passe d'accès temporaire (chemin à confirmer sur le portail).

1.3 Points forts d'authentification (Authentication Strength)

Chemin : Entra ID → Méthodes d'authentification → Points forts d'authentification (également accessible par Accès conditionnel → Points forts d'authentification)

N°	Étape	Action
1	3 niveaux intégrés	**Authentification multifacteur (niveau 1)** : combinaisons de méthodes qui répondent à une authentification forte, par exemple mot de passe + SMS. Utilisée par CA-01. **Authentification multifacteur sans mot de passe (niveau 2)** : méthodes sans mot de passe, comme Microsoft Authenticator. **MFA anti-hameçonnage (niveau 3)** : méthodes sans mot de passe résistantes au hameçonnage, comme la clé de sécurité FIDO2.
2	Vérification	Confirmer que les 3 niveaux intégrés (colonne Type : Intégré) sont visibles. Dans la liste, le portail peut les afficher sous leur nom anglais : Multifactor authentication, Passwordless MFA, Phishing-resistant MFA. Le détail d'une force s'ouvre en cliquant sur son nom (« Afficher la force de l'authentification »). Aucune création nécessaire sauf besoin spécifique.

1.4 Campagne d'inscription

Chemin : Entra ID → Méthodes d'authentification → Campagne d'inscription

N°	Étape	Action
1	État	Valeur par défaut observée : « Managé par Microsoft » (Microsoft ajuste les paramètres de la campagne). Les champs Méthode d'authentification, « Nombre de jours autorisés pour la répétition » et « Nombre limité de répétitions » sont grisés dans cet état.
2	Périmètre	Inclure : Tous les utilisateurs. Exclure → Sélectionner un groupe → `GRP-CA-BreakGlass`.
3	Enregistrer	Cliquer Enregistrer.

INFO la campagne d'inscription invite (rappel après connexion) les utilisateurs à configurer Microsoft Authenticator ou une clé d'accès (FIDO2). Elle ne force pas l'enregistrement : c'est CA-01 qui l'impose. Les utilisateurs doivent avoir la méthode activée dans les stratégies pour être éligibles au rappel.

CONSEIL envoyez un email aux utilisateurs AVANT l'activation de CA-01 avec le lien d'enregistrement : https://aka.ms/mfasetup. Sans préavis, ils seront bloqués à leur prochaine connexion.

ATTENTION **CA pendant l'enregistrement.** Depuis le 13 juillet 2026 (déploiement du 6 au 13 juillet 2026, avis Microsoft MC1326253), les politiques CA ciblant l'action utilisateur « Inscrire des informations de sécurité » s'appliquent aussi pendant le provisionnement de Windows Hello Entreprise et de macOS Platform SSO. Le MVC ne crée pas de politique sur cette action : aucun impact. Si le client en ajoute une, testez-la en mode Rapport avant application, sous peine de bloquer l'enregistrement des nouveaux collaborateurs.

Partie 2 : Emplacements nommés

nLPD art. 8 al. 1 : contextualisation géographique des accès. La nLPD art. 8 exige des mesures techniques adaptées au risque. Définir les zones géographiques légitimes d'accès permet de bloquer les connexions depuis des pays à risque et de conditionner le MFA selon la localisation. Les emplacements nommés sont la base de la politique CA-03.

ATTENTION créez les emplacements nommés AVANT les politiques CA qui les référencent. Un emplacement inexistant invalide la politique CA.

2.1 Pays autorisés

Chemin : entra.microsoft.com → Entra ID → Accès conditionnel → Emplacements nommés → + Emplacement des pays

N°	Étape	Action
1	Nom	`Pays-Autorises-[Client]`
2	Méthode	Méthode de recherche de pays : « Déterminer l'emplacement avec l'adresse IP (IPv4 et IPv6) » (valeur par défaut).
3	Pays	Cocher : CH (Suisse). Ajouter selon les besoins réels du client : DE, FR, IT, AT, LI. Documenter chaque pays ajouté avec la justification métier.
4	Pays inconnus	Case « Inclure des pays/régions inconnus » : laisser DÉCOCHÉE. Les pays non listés seront bloqués par CA-03.
5	Créer	Cliquer Créer.

2.2 Bureau (IP fixe), optionnel

Chemin : Emplacements nommés → menu « … » de la barre d'outils → + Emplacement des plages d'adresses IP

N°	Étape	Action
1	Nom	`Bureau-[Client]`
2	Marqué approuvé	Cocher : Marquer comme emplacement approuvé.

N°	Étape	Action
3	Plage IP	Cliquer sur le bouton « + », puis saisir l'IP fixe du bureau en CIDR (exemple : 203.0.113.10/32). Demander à l'opérateur si nécessaire.
4	Créer	Cliquer Créer.

INFO aucune politique du MVC ne référence cet emplacement. Il sert de repère dans les journaux et aux éventuelles exceptions documentées du client. Si le client n'a pas d'IP fixe, sautez cet emplacement. CA-01 s'applique avec MFA depuis le bureau, sans exception.

Partie 3 : CA-01, MFA pour tous les utilisateurs

nLPD art. 8 al. 1 : première mesure de protection contre la compromission de compte. La nLPD art. 8 exige des mesures techniques de protection proportionnelles au risque. Le MFA est la mesure la plus efficace contre la compromission de compte par credential stuffing : attaque automatisée testant des millions de mots de passe volés. Sans MFA, un mot de passe volé suffit à contourner toute la protection Purview.

IMPORTANT exigez le MFA sur le compte admin AVANT d'activer CA-01 en mode Application. Sans cela, CA-01 peut déclencher une boucle d'authentification sur le compte admin et bloquer l'accès au portail.

N°	Étape	Action
C1	Mode rapport	Activer CA-01 en mode Rapport uniquement pendant 7 jours. Vérifier dans les journaux (Surveillance → Journaux de connexion → colonne « Résultat de la politique CA ») que la politique s'applique aux bons utilisateurs.
1	Nom	`CA-01-MFA-Tous-Utilisateurs`
2	Utilisateurs → Inclure	Tous les utilisateurs.
3	Utilisateurs → Exclure	`GRP-CA-BreakGlass`.
4	Ressources cibles	Toutes les ressources (anciennement « Toutes les applications cloud »).
5	Contrôles d'accès → Octroyer	Accorder l'accès → cocher « Exiger la force de l'authentification » → choisir « Authentification multifacteur » → Sélectionner. Ne pas cocher en plus « Exiger une authentification multifacteur » : le portail refuse de combiner les deux.
6	Activer une stratégie	Rapport uniquement → 7 jours → puis Activé.
7	Créer	Cliquer Créer.

CONSEIL **test.** Connexion avec un compte utilisateur standard en navigation privée → l'invite MFA apparaît. Connexion bga1 → pas d'invite MFA de la politique CA (compte exclu).

3.2 CA-09, MFA anti-hameçonnage pour les administrateurs

nLPD art. 8 al. 1 : protection renforcée des comptes à privilèges. Un compte administrateur compromis expose l'ensemble du tenant. Les administrateurs doivent s'authentifier avec une méthode résistante au hameçonnage (clé FIDO2, clé d'accès), pas avec un code SMS ou une notification.

IMPORTANT chaque administrateur doit avoir enregistré une clé d'accès (FIDO2) AVANT le passage en Application. Utilisez une Passe d'accès temporaire (§1.2) pour l'enregistrement. Sans cela, l'administrateur est bloqué. Pour les administrateurs, privilégiez les passkeys liés à l'appareil et les clés physiques avec attestation lorsque le profil de clé le permet. La connexion sans mot de passe par Microsoft Authenticator n'est pas automatiquement résistante au hameçonnage : vérifiez le contenu de la force « MFA anti-hameçonnage » dans le tenant. Si le tenant contient déjà une politique équivalente (par exemple `CA-Phishing-Resistant-Admins`), ne créez pas de doublon : alignez-la sur les étapes ci-dessous et gardez un seul nom.

N°	Étape	Action
1	Nom	`CA-09-MFA-Phishing-Resistant-Administrateurs`
2	Utilisateurs → Inclure	Sélectionner les utilisateurs et groupes → Rôles d'annuaire (libellé à confirmer sur le portail) → au minimum : Administrateur général, Administrateur de la sécurité, Administrateur de l'authentification, Administrateur de stratégie d'authentification, Administrateur de l'accès conditionnel, ainsi que les rôles d'administration Exchange, SharePoint et Intune réellement utilisés.
3	Utilisateurs → Exclure	`GRP-CA-BreakGlass`.
4	Ressources cibles	Toutes les ressources.
5	Contrôles d'accès → Octroyer	Accorder l'accès → cocher « Exiger la force de l'authentification » → choisir « MFA anti-hameçonnage » (Phishing-resistant MFA) → Sélectionner.
6	Activer une stratégie	Rapport uniquement → 7 jours → puis Activé.
7	Créer	Cliquer Créer.

Partie 4 : CA-02, Blocage de l'authentification héritée

nLPD art. 8 al. 1 : fermeture du vecteur de contournement du MFA. Les protocoles IMAP, POP3, SMTP AUTH et Exchange ActiveSync basique ne supportent pas l'accès conditionnel : ils contournent donc le MFA. Un compte avec CA-01 actif reste entièrement vulnérable si l'authentification héritée n'est pas bloquée.

N°	Étape	Action
C1	Inventaire et rapport	Les applications M365 modernes (Outlook, Teams, SharePoint, Outlook mobile) utilisent OAuth 2.0 et ne sont pas affectées. En revanche, imprimantes multifonctions, scanners et anciens logiciels utilisent souvent SMTP AUTH ou IMAP. Avant l'application : Surveillance → Journaux de connexion → filtre « Application cliente » (IMAP4, POP3, SMTP, Exchange ActiveSync, Autres clients) sur 7 à 14 jours, puis traiter chaque usage trouvé.
1	Nom	`CA-02-Blocage-Auth-Heritee`
2	Utilisateurs → Inclure	Tous les utilisateurs.
3	Utilisateurs → Exclure	`GRP-CA-BreakGlass`.
4	Ressources cibles	Toutes les ressources (anciennement « Toutes les applications cloud »).
5	Conditions → Applications clientes	Configurer : Oui → cocher, sous « Clients d'authentification hérités » : Clients Exchange ActiveSync + Autres clients (IMAP, POP3, SMTP legacy). Laisser Navigateur et Applications mobiles et clients de bureau décochés.
6	Contrôles d'accès → Octroyer	Bloquer l'accès → Sélectionner.
7	Activer une stratégie	Rapport uniquement → 7 à 14 jours → puis Activé.
8	Créer	Cliquer Créer.

CONSEIL **test.** Tentative de connexion IMAP ou Outlook 2010 avec un compte utilisateur → erreur « Accès bloqué par les politiques d'accès conditionnel ».

Partie 5 : CA-03, Filtrage géographique

nLPD art. 8 al. 1 : réduction de la surface d'attaque géographique. La grande majorité des attaques de credential stuffing provient de pays tiers. Bloquer les connexions depuis des pays non autorisés réduit significativement l'exposition, sans impact sur les utilisateurs légitimes connectés depuis la Suisse et les pays voisins configurés.

N°	Étape	Action
C1	Mode rapport	14 jours en mode Rapport. Vérifier que personne de légitime ne serait bloqué, notamment les collaborateurs en déplacement.
1	Nom	`CA-03-Blocage-Pays-Non-Autorises`
2	Utilisateurs → Inclure	Tous les utilisateurs.
3	Utilisateurs → Exclure	`GRP-CA-BreakGlass`.
4	Ressources cibles	Toutes les ressources (anciennement « Toutes les applications cloud »).
5	Réseau (ou Conditions → Emplacements) → Configurer : Oui → Inclure	N'importe quel réseau ou emplacement.
6	Réseau → Exclure	Réseaux et emplacements sélectionnés → `Pays-Autorises-[Client]`.
7	Contrôles d'accès → Octroyer	Bloquer l'accès → Sélectionner.
8	Activer une stratégie	Rapport uniquement → 14 jours → puis Activé.
9	Créer	Cliquer Créer.

ATTENTION **avant d'activer.** Si des collaborateurs se connectent régulièrement depuis des pays non listés (déplacements professionnels), ajoutez ces pays à `Pays-Autorises-[Client]` avant de passer en Application.

Partie 6 : CA-04, Token Protection

nLPD art. 8 al. 1 : protection contre le vol de session post-MFA. Les attaques AiTM contournent le MFA en interceptant le cookie de session. Token Protection lie le jeton de session à l'appareil, ce qui réduit le risque de rejeu d'un jeton volé depuis un autre appareil, sur les plateformes et applications compatibles. Les appareils Windows doivent être joints à Entra, joints hybrides ou inscrits, avec des clients à jour qui passent par le courtier d'authentification de la plateforme (WAM). Windows Hello Entreprise (WHfB), TPM 2.0 et Cloud Kerberos Trust ne sont pas cités comme prérequis dans le guide de déploiement Windows de Microsoft consulté le 8 novembre 2026. Pour le contexte de l'attaque : annexe AiTM / Cookie Hijacking.

ATTENTION conditions réelles pour une PME cloud-only (périmètre MVC).

Token Protection supporte les applications natives (Outlook, Teams, OneDrive, Word, Excel, PowerPoint, OneNote, Edge pour la connexion au profil uniquement, etc.) sur Windows, avec Exchange Online, SharePoint Online et Teams comme ressources. Dans un navigateur, seule une préversion limitée existe (Windows et macOS, pour certaines applications web qui accèdent à Azure Resource Manager) : les applications web courantes ne sont pas protégées, et rien n'est supporté dans un navigateur sur iOS/iPadOS. Côté Apple (macOS 14+, iOS/iPadOS 16+), la page de documentation Microsoft consultée le 7 novembre 2026 reste incohérente : son tableau indique la disponibilité générale pour les applications natives, alors qu'une autre section parle de « préversion ». Les appareils doivent être gérés par MDM, avec le plug-in Microsoft Enterprise SSO (ou Platform SSO sur macOS) ; les appareils Apple non gérés ne sont pas supportés. Ne pas activer en Application sans test. Les applications natives Mail et Calendrier d'Apple ne supportent pas Token Protection : les utilisateurs seraient bloqués.

Types d'enregistrement Windows non supportés (accès bloqué, code `signInSessionStatusCode` 1003 dans les journaux) : appareils déployés par inscription en masse (bulk enrollment), Windows Autopilot en mode self-deploying, Cloud PC Windows 365 joints à Entra, hôtes de session Azure Virtual Desktop joints à Entra. Excluez-les avec un filtre d'appareil.

En environnement hybride (Hybrid Entra Join + AD on-prem), le Cloud Kerberos Trust concerne le scénario WHfB et l'accès aux ressources locales, pas Token Protection elle-même : hors périmètre MVC, voir l'annexe AiTM §6.

Autres exclusions documentées par Microsoft : navigateurs, modules PowerShell SharePoint, extensions Visual Studio Code, clients Office perpétuels antérieurs à 2024, Surface Hub et Teams Rooms. Microsoft recommande aussi, en complément, de bloquer les plateformes inconnues et d'exiger un appareil conforme sur les plateformes connues (voir CA-08).

Dans une PME suisse, la majorité des accès passe par navigateur ou appareils Apple : Token Protection ne protège pas ces vecteurs.

N°	Étape	Action
C1	Prérequis	Parc Windows 10 ou supérieur, joint à Entra, joint hybride ou inscrit, TPM 2.0 actif. WHfB recommandé (voir MVC Intune : Appareils → Inscription → Windows → Windows Hello Entreprise). Le Cloud Kerberos Trust n'est requis qu'en hybride (Hybrid Entra Join + AD on-prem), hors périmètre MVC. Aucun appareil Apple dans le périmètre de la politique.
C2	Déployer en 2 temps	Phase 1 (ce guide) : créer CA-04 en Rapport uniquement, groupe pilote Direction + admins. Phase 2 (après MVC Intune) : activer en Application uniquement après analyse des journaux de connexion interactifs et non interactifs sur une période couvrant l'usage normal, et si 100 % des appareils dans le périmètre sont Windows avec TPM 2.0 (`dsregcmd /status` → `AzureAdJoined : YES` + `TpmProtected : YES`). Ce contrôle TPM est un critère interne de validation renforcée du MVC, pas un prérequis universel documenté par Microsoft.
1	Nom	`CA-04-Token-Protection-Windows`
2	Utilisateurs → Inclure	Groupe pilote (Direction + admins). Ne pas inclure tous les utilisateurs avant validation terrain.
3	Utilisateurs → Exclure	`GRP-CA-BreakGlass`.
4	Ressources cibles	Office 365 Exchange Online + Office 365 SharePoint Online + Microsoft Teams Services (recommandation du guide Microsoft de déploiement Windows). Ne pas sélectionner le groupe d'applications « Office 365 » ni « Toutes les ressources ». Si Windows App est déployé : ajouter Azure Virtual Desktop, Windows 365 et Windows Cloud Login.
5	Conditions → Plateformes d'appareils	Configurer : Oui → Inclure : Windows.
6	Conditions → Applications clientes	Configurer : Oui → cocher uniquement « Applications mobiles et clients de bureau ». Laisser « Navigateur » décoché.

N°	Étape	Action
7	Session	Contrôles d'accès → Session → cocher : Exiger une protection par jeton pour les sessions de connexion.
8	Activer une stratégie	Rapport uniquement → Créer. Passer en Application après MVC Intune, analyse des journaux et exclusion des cas non supportés (filtre d'appareil).

CONSEIL **test en Rapport.** Journaux de connexion (interactifs et non interactifs) → filtrer sur CA-04 → onglet « Accès conditionnel » du détail → résultat de la politique et du contrôle de session. Si des échecs apparaissent pour des applications ou appareils non supportés : ajustez le périmètre avant tout passage en Application.

Partie 7 : CA-05, Session limitée sur appareils non gérés

nLPD art. 8 al. 1 : contrôle des accès depuis les appareils personnels. Un appareil personnel non géré peut être compromis, partagé ou perdu sans que l'organisation en soit informée. Limiter les sessions SharePoint et OneDrive sur ces appareils (lecture seule, pas de téléchargement) réduit le risque d'exfiltration de données personnelles.

N°	Étape	Action
C1	Prérequis SharePoint	Centre d'administration SharePoint → Stratégies → Contrôle d'accès → Appareils non gérés → Autoriser un accès limité au web uniquement (libellé exact à confirmer sur le portail ; la page de documentation Microsoft « control access from unmanaged devices » fait foi). Dans le même écran, vérifier si une option de lecture seule ou de restriction de téléchargement existe ; elle n'est pas documentée ici. Ce paramètre doit être actif pour que CA-05 soit efficace. Par défaut, il autorise la consultation **et la modification** dans le navigateur ; il bloque téléchargement, impression, synchronisation et applications de bureau. Pour interdire aussi la modification des fichiers Office dans le navigateur : `Set-SPOTenant -ConditionalAccessPolicy AllowLimitedAccess -AllowEditing $false`. Pour un site entièrement en lecture seule : paramètre `-ReadOnlyForUnmanagedDevices $true` (documenté par Microsoft pour un site avec `Set-SPOSite`; vérifier la portée dans le tenant). **Attention** : activer l'option depuis le centre d'administration SharePoint désactive les politiques créées auparavant depuis cette page et crée une politique pour tous les utilisateurs ; les personnalisations ne sont pas reprises. Les liens « Anyone » ne sont pas concernés. Délai d'effet : jusqu'à 24 heures.
1	Nom	`CA-05-Session-Limitee-Appareils-Non-Geres`
2	Utilisateurs	Inclure : Tous les utilisateurs. Exclure : `GRP-CA-BreakGlass`.
3	Ressources cibles	Office 365 SharePoint Online.
4	Conditions → Filtre pour les appareils	Configurer : Oui → Inclure les appareils filtrés dans la stratégie → Syntaxe de la règle → Modifier : `device.isCompliant -ne True AND device.trustType -ne "ServerAD"` (« -ne True » couvre aussi les appareils sans état de conformité, par exemple non inscrits). La seconde condition exclut volontairement tous les appareils joints hybrides (`ServerAD`), même non conformes : ils sont traités comme gérés. Retirez cette condition si le client veut aussi restreindre les appareils hybrides non conformes.
5	Session	Contrôles d'accès → Session → cocher : Utiliser les restrictions appliquées par l'application.
6	Activer une stratégie	Rapport uniquement → 7 jours → puis Activé.

N°	Étape	Action
7	Créer	Cliquer Créer.

CONSEIL **test en trois cas.** (1) Appareil géré et conforme : accès normal. (2) Appareil inscrit mais non conforme : accès web limité. (3) Appareil personnel non géré, navigateur : accès web limité, sans téléchargement, impression ni synchronisation ; la modification dans le navigateur reste possible sauf si elle a été interdite (`-AllowEditing $false`). Les liens de partage anonymes ne dépendent pas de cette politique : à documenter séparément dans la politique de partage du client.

Partie 8 : CA-06, Connexions hors horaires, expérimental

nLPD art. 8 al. 1 : réduction de la surface d'attaque temporelle. Une connexion en dehors des heures habituelles est un signal utile pour repérer un accès inhabituel. CA-06 signale (mode Rapport) les connexions en dehors des heures ouvrables ; le blocage reste une option à évaluer avec le client.

ATTENTION **mesure complémentaire expérimentale (niveau 3).** La condition temporelle n'est pas disponible dans l'interface graphique Entra ID : elle se configure via Microsoft Graph, endpoint **beta**, dont le comportement peut changer sans préavis. Le schéma `conditions.times` a été validé et évalué en mode Rapport sur un tenant réel, mais la propriété `times` n'est pas documentée dans le schéma Microsoft Graph beta publié et n'est donc pas prise en charge officiellement. Cette politique reste **optionnelle** : à ne pas déployer en Application sans validation client, test sur plusieurs semaines et alternative d'accès documentée. Excluez impérativement `GRP-CA-BreakGlass`.

INFO **note nLPD.** Cette politique doit être documentée dans le registre des activités de traitement comme contrôle d'accès système (et non évaluation des employés), communiquée aux utilisateurs dans la politique de sécurité IT, et appliquée de manière proportionnée au risque identifié.

N°	Étape	Action
C1	Plage couverte	Lundi-vendredi de 07h00 à 19h00, heure suisse. Week-end entier hors plage. Les horaires du JSON sont en UTC : 05h00-17h00 en été (CEST = UTC+2), 06h00-18h00 en hiver (CET = UTC+1). Le JSON ci-dessous est la version d'été : à adapter au changement d'heure (fin octobre et fin mars).
C2	Exclusions	`GRP-CA-BreakGlass` impérativement. Exclure aussi les comptes de service si des traitements nocturnes légitimes existent (synchronisation Entra Connect, sauvegardes automatisées).
1	Créer la politique dans Entra ID	entra.microsoft.com → Accès conditionnel → + Nouvelle stratégie. Nom : `CA-06-Hors-Horaires-Experimental`. Utilisateurs : Tous, exclure `GRP-CA-BreakGlass`. Ressources : Toutes les ressources. Octroyer : Bloquer l'accès. Activer une stratégie : Rapport uniquement → Créer.
2	Récupérer l'ID de la politique	Graph Explorer (https://aka.ms/ge) → `GET https://graph.microsoft.com/beta/identity/conditionalAccess/policies` → rechercher `CA-06-Hors-Horaires-Experimental` → copier l'ID (format UUID).
3	PATCH Graph API	`PATCH https://graph.microsoft.com/beta/identity/conditionalAccess/policies/{ID}` avec le corps JSON ci-dessous. La condition exclut les heures ouvrables (lun-ven 05h00-17h00 UTC) : tout le reste (nuits et week-end) est couvert par la politique.

Corps JSON (été, CEST)

```
{
  "conditions": {
    "times": {
      "includeAllTimes": true,
      "excludeDays": {
        "daysOfWeek": ["monday", "tuesday", "wednesday", "thursday", "friday"],
        "timeZone": "UTC",
        "startTime": "05:00:00",
        "endTime": "17:00:00",
        "allDay": false
      }
    }
  }
}
```

CONSEIL **test en Rapport.** Journaux de connexion → filtrer sur CA-06 → colonne « Résultat CA ». Tester avec un compte **non exclu** (un compte exclu affiche « non appliquée ») : une connexion le week-end ou après 19h00 doit apparaître « Rapport - Échec » ; une connexion en heure ouvrable ne doit pas être signalée. Les heures des journaux sont en UTC.

CONSEIL **SIEM (UTMStack).** En mode Rapport, la politique ne bloque rien : la règle UTMStack M14 (Sign-In Blocked by Conditional Access Policy) ne se déclenchera qu'après passage en Application. En Rapport, exploitez les journaux de connexion (résultat « Rapport - Échec »). Une fois en Application, corréler M14 avec M3 (Impossible Travel) si le blocage coïncide avec un pays inhabituel.

Partie 9 : CA-08, Exiger un appareil conforme

nLPD art. 8 al. 1 : contrôle d'accès par état de sécurité de l'appareil. Un appareil non géré ou non conforme (BitLocker inactif, antivirus absent, version OS obsolète) représente un risque d'exfiltration et de compromission. CA-08 bloque l'accès aux ressources M365 depuis tout appareil ne répondant pas aux critères de conformité Intune.

ATTENTION cette politique est créée ici en mode Rapport uniquement. Elle ne sera activée en Application qu'après le déploiement du MVC Intune + Defender, une fois les politiques de conformité déployées et les appareils en statut « Conforme ».

N°	Étape	Action
C1	Déployer en 2 temps	Phase 1 (ce guide) : créer CA-08 en Rapport uniquement. Phase 2 (après MVC Intune) : passer en Application une fois les appareils conformes dans Intune.
1	Nom	`CA-08-Exiger-Appareil-Conforme`
2	Utilisateurs → Inclure	Tous les utilisateurs.
3	Utilisateurs → Exclure	`GRP-CA-BreakGlass`.
4	Ressources cibles	Toutes les ressources (anciennement « Toutes les applications cloud »).
5	Contrôles d'accès → Octroyer	Accorder l'accès → cocher « Exiger que l'appareil soit marqué comme conforme » → Sélectionner.
6	Activer une stratégie	Rapport uniquement → Créer. Passer en Application après déploiement Intune (voir MVC Intune + Defender, Partie 12).

Partie 10 : SSPR, Réinitialisation du mot de passe

nLPD art. 8 al. 1 : traçabilité des réinitialisations et continuité d'accès. Le SSPR et ses journaux (journal d'audit Entra ID) contribuent à la sécurité et à la traçabilité des opérations de gestion des identités, dans le cadre des mesures adaptées au risque de la nLPD art. 8. Il réduit aussi les appels helpdesk post-activation MFA, fréquents lors des premiers jours de déploiement.

10.1 Activer SSPR

Chemin : entra.microsoft.com → Entra ID → Réinitialisation de mot de passe → Propriétés

N°	Étape	Action
1	Statut	Réinitialisation de mot de passe libre-service : Sélectionné (pas Tout, pour exclure les comptes de service).
2	Groupe	+ Sélectionner le groupe → créer `GRP-SSPR-Utilisateurs` → ajouter tous les utilisateurs standards.
3	Enregistrer	Cliquer Enregistrer.

10.2 Méthodes et notifications

Chemin : Réinitialisation de mot de passe → Méthodes d'authentification

N°	Étape	Action
1	Nombre de méthodes requises	2
2	Méthodes	Activer : Notification d'application mobile, E-mail. « Téléphone mobile » : transitoire seulement (voir l'avertissement MC1536049 ci-dessous). Ne pas activer « Questions de sécurité » : le portail annonce leur mise hors service en mars 2027.
3	Enregistrer	Cliquer Enregistrer.
4	Notifications	Réinitialisation de mot de passe → Notifications. « Notifier les utilisateurs lors des réinitialisations de mot de passe ? » : Oui. « Notifier tous les administrateurs quand d'autres administrateurs réinitialisent leur mot de passe ? » : Oui (la valeur par défaut observée est Non). Enregistrer.

INFO **environnement hybride.** En environnement AD on-prem avec Entra Connect : Réinitialisation de mot de passe → Intégration locale → cocher « Activer la réécriture du mot de passe pour les utilisateurs synchronisés ». La page affiche aussi l'état de l'agent de synchronisation Microsoft Entra Connect (« Configuration terminée » attendu) et la case « Voulez-vous autoriser les utilisateurs à déverrouiller les comptes sans réinitialiser leur mot de passe ? ». Sans la réécriture, le mot de passe est réinitialisé dans le cloud mais pas dans l'AD local.

CONSEIL **test.** https://aka.ms/sspr → réinitialisation avec 2 méthodes → succès → notification reçue → connexion avec le nouveau mot de passe.

ATTENTION **changement SSPR de novembre 2026.** Microsoft arrête de prendre en compte les coordonnées issues de l'annuaire (téléphone mobile, téléphone professionnel, email alternatif) pour vérifier l'identité lors d'une réinitialisation : seules les méthodes explicitement enregistrées par l'utilisateur (https://aka.ms/mfasetup ou mysignins.microsoft.com) sont acceptées. Un utilisateur sans méthode enregistrée ne peut plus réinitialiser son mot de passe seul. L'application, d'abord annoncée pour le 7 septembre 2026, a été repoussée par Microsoft (avis MC1325414) : campagne d'enregistrement depuis le 5 octobre 2026, application du 7 au 9 novembre 2026, avec un déploiement progressif jusqu'à mi-novembre. Vérifiez la couverture avant et après : entra.microsoft.com → Méthodes d'authentification → Détails d'inscription des utilisateurs.

ATTENTION **fin du SMS et de l'appel vocal fournis par Microsoft pour le SSPR (avis MC1536049, publié le 3 novembre 2026).** Le retrait du SMS et de l'appel vocal fournis par Microsoft débute le **1er février 2027** pour les utilisateurs standards et le **1er juillet 2027** pour les administrateurs généraux et les utilisateurs externes. Pour le SSPR, la transition dure 50 jours à partir du moment où le retrait atteint le tenant : il n'y a pas de date de fin unique pour tous. Une option de fournisseur de téléphonie géré par le client est annoncée. Une clé d'accès seule ne suffit pas à satisfaire le SSPR. Conséquence pour le MVC : privilégier Notification d'application mobile et E-mail, et ne pas bâtir le SSPR sur le téléphone. Les calendriers évoluent : revérifiez le centre de messages avant chaque déploiement.

Partie 11 : Tests et validation

Test	Scénario	Résultat attendu
T1	MFA déclenché (CA-01)	Navigation privée → connexion utilisateur standard → invite MFA → connexion réussie après MFA.
T2	Break-glass non bloqué	Connexion bga1 → invite MFA portail (normale depuis 2025) mais pas de blocage CA-01 (compte exclu). FIDO2 ou Authenticator requis pour passer le MFA portail. Connexion bga2 → idem.
T3	Auth héritée bloquée (CA-02)	Client IMAP ou Outlook 2010 → erreur « Accès bloqué par les politiques d'accès conditionnel ».
T4	Pays bloqué (CA-03)	VPN vers un serveur hors `Pays-Autorises-[Client]` → connexion bloquée.
T5	Session limitée (CA-05)	Appareil non géré → SharePoint → accès en lecture seule, pas de téléchargement.
T6	SSPR	https://aka.ms/sspr → 2 méthodes → nouveau mot de passe → notification reçue.
T7	Journaux de connexion	entra.microsoft.com → Surveillance → Journaux de connexion → politiques CA visibles dans la colonne « Résultat de la politique CA ».
T8	Token Protection (CA-04)	Poste Windows du groupe pilote, Outlook, OneDrive et Teams (application native) → journaux de connexion → CA-04 en Rapport : succès attendu. Vérifier qu'aucun échec ne concerne une application ou un appareil non supporté avant passage en Application.
T9	Appareil conforme (CA-08)	Appareil non conforme ou non inscrit → CA-08 apparaît « Rapport - Échec » ; appareil conforme → « Rapport - Succès ».
T10	Hors horaires (CA-06)	Compte non exclu, connexion en heures ouvrables → non signalée ; connexion le soir ou le week-end → « Rapport - Échec ».
T11	Administrateurs (CA-09)	En Rapport : administrateur avec clé d'accès enregistrée → succès ; sans clé d'accès → échec, à corriger. Puis après passage en Application : connexion administrateur avec clé d'accès réussie.

Checklist de remise client

☐	Action	Vérification	nLPD
☐	Deux comptes break-glass créés (bga1 + bga2, Administrateur général permanent, FIDO2, alerte de connexion en place)	entra.microsoft.com → Utilisateurs	
☐	Groupe `GRP-CA-BreakGlass` créé (bga1 + bga2)	entra.microsoft.com → Groupes	
☐	Security Defaults désactivé	entra.microsoft.com → Propriétés	
☐	Authenticator + FIDO2 (passkeys liés à l'appareil) activés ; SMS optionnel	Entra ID → Méthodes d'auth	art. 8
☐	Passe d'accès temporaire activée (usage unique, 1 h par défaut)	Entra ID → Méthodes → Passe d'accès temporaire	
☐	Campagne d'inscription active (tous les utilisateurs, sauf break-glass)	Entra ID → Méthodes → Campagne d'inscription	
☐	Emplacement `Pays-Autorises-[Client]` créé	CA → Emplacements nommés	art. 8
☐	CA-01 MFA : Application (après 7 j de rapport)	CA → Stratégies → CA-01	art. 8
☐	CA-02 Auth héritée : Application (après 7 à 14 j de rapport et inventaire)	CA → Stratégies → CA-02	art. 8
☐	CA-09 MFA anti-hameçonnage administrateurs : Application (après 7 j de rapport et clés d'accès enregistrées)	CA → Stratégies → CA-09	art. 8
☐	CA-03 Filtrage géo : Application (après 14 j de rapport)	CA → Stratégies → CA-03	art. 8
☐	CA-04 Token Protection : Rapport uniquement (Application après MVC Intune)	CA → Stratégies → CA-04	art. 8
☐	CA-05 Session limitée : Application	CA → Stratégies → CA-05	art. 8
☐	CA-06 Hors horaires (expérimental, optionnel) : Rapport uniquement	CA → Stratégies → CA-06	art. 8
☐	CA-08 Appareil conforme : Rapport uniquement (Application après MVC Intune)	CA → Stratégies → CA-08	art. 8
☐	SSPR activé pour `GRP-SSPR-Utilisateurs` (2 méthodes)	Entra ID → Réinit. MDP	art. 8
☐	Test T1 MFA déclenché validé	Navigation privée	
☐	Test T2 Break-glass non bloqué validé	Connexion bga1	
☐	Test T3 Auth héritée bloquée validé	Client IMAP	
☐	Test T4 Pays bloqué validé	VPN	art. 8
☐	Test T5 Session limitée validé (trois cas)	Appareil non géré	art. 8
☐	Test T6 SSPR fonctionnel validé	https://aka.ms/sspr	
☐	Test T7 Journaux de connexion consultés	Surveillance → Journaux de connexion	
☐	Tests T8 à T10 validés en Rapport (CA-04, CA-08, CA-06) ; T11 (CA-09) validé en Rapport puis en Application	Journaux de connexion	
☐	Dernière révision du guide et dates Microsoft revérifiées	Centre de messages	

Annexe A : Glossaire

Terme	Définition
AiTM (Adversary-in-the-Middle)	Attaque interceptant la session après un MFA réussi en volant le cookie de session. Token Protection (CA-04) bloque cette attaque. Voir l'annexe AiTM.
Authentication Strength	Fonctionnalité CA P1 définissant le niveau minimal de méthode d'authentification requis. 3 niveaux intégrés : Authentification multifacteur, Authentification multifacteur sans mot de passe, MFA anti-hameçonnage.
Break-glass	Comptes admin d'urgence exclus de toutes les politiques CA. Utilisés uniquement si le tenant est verrouillé. Deux comptes recommandés avec des méthodes différentes. Doivent avoir FIDO2 ou CBA enregistré (MFA des portails admin obligatoire depuis 2025). Noms neutres recommandés en production.
CAE (Continuous Access Evaluation)	Révocation des sessions M365 en temps réel si un changement est détecté (désactivation de compte, IP suspecte).
Credential stuffing	Attaque automatisée testant des millions de paires identifiant/mot de passe volés sur d'autres services.
Contrôles personnalisés / MFA externe	Les « Contrôles personnalisés » CA (MFA tiers) sont remplacés par MFA externe (External MFA). Depuis septembre 2026, il n'est plus possible d'ajouter ou de modifier des contrôles personnalisés ; le retrait complet est prévu début 2027 (source : documentation Microsoft Learn). Non utilisés dans le MVC : à vérifier si le client a un fournisseur MFA tiers.
Emplacement nommé	Zone géographique (pays) ou plage IP définie dans Entra ID, utilisée comme condition dans les politiques CA.
Entra Connect / Cloud Sync	Outil de synchronisation entre l'Active Directory local et Entra ID. Requis en environnement hybride. Microsoft encourage Entra Cloud Sync (agent léger cloud-natif). Pour Entra Connect Sync, la version 2.6.84.0 ou supérieure avec l'authentification basée sur une application est obligatoire avant le 7 avril 2027, sans quoi la synchronisation s'arrête (échéance précédemment annoncée au 30 septembre 2026, avec la version 2.5.79.0, puis repoussée).
FIDO2 / Passkey	Standard cryptographique pour l'authentification sans mot de passe. Résistant au phishing car lié à l'URL de destination.
MFA	Multi-Factor Authentication. Exige deux facteurs : mot de passe + téléphone (ou biométrie).
Mode Rapport uniquement	Les politiques CA sont évaluées mais n'appliquent aucun contrôle. Permet de tester l'impact avant activation.
PFPDT	Préposé fédéral à la protection des données et à la transparence, autorité de contrôle suisse.
SSPR	Self-Service Password Reset. Réinitialisation autonome et auditée du mot de passe sans helpdesk.
TAP (Temporary Access Pass, « Passe d'accès temporaire »)	Code temporaire à usage unique pour enregistrer le premier facteur MFA lors de l'onboarding.
Token Protection	Fonctionnalité CA P1 liant les jetons de session à l'appareil émetteur. Réduit le risque de rejeu de jetons volés sur les plateformes et applications compatibles.

Annexe B : Checklist MVC complète avec références nLPD

Prérequis

☐	Action	Portail / Chemin	nLPD
☐	Deux comptes break-glass créés (bga1 + bga2), Administrateur général permanent, FIDO2	entra.microsoft.com → Utilisateurs	
☐	Alerte sur toute connexion break-glass en place, test tous les 90 jours	Azure Monitor, SIEM ou revue des journaux	
☐	Groupe `GRP-CA-BreakGlass` créé	entra.microsoft.com → Groupes	
☐	Security Defaults désactivé	entra.microsoft.com → Propriétés → Paramètres de sécurité	

Méthodes d'authentification

☐	Action	Portail / Chemin	nLPD
☐	Authenticator activé, tous les utilisateurs	Entra ID → Méthodes d'auth → Authenticator	art. 8
☐	FIDO2/Passkeys activé : liés à l'appareil (Authenticator, clés physiques) ; synchronisés non autorisés pour les administrateurs	Entra ID → Méthodes d'auth → Passkey	art. 8
☐	SMS : optionnel et transitoire	Entra ID → Méthodes d'auth → SMS	
☐	Passe d'accès temporaire activée, usage unique, 1 heure par défaut	Entra ID → Méthodes d'auth → Passe d'accès temporaire	
☐	Campagne d'inscription active (tous les utilisateurs, sauf break-glass)	Entra ID → Méthodes d'auth → Campagne d'inscription	
☐	MFA per-user legacy vérifié (tous en Désactivé)	admin.microsoft.com → Utilisateurs actifs → MFA	

Emplacements nommés

☐	Action	Portail / Chemin	nLPD
☐	Emplacement `Pays-Autorises-[Client]` créé (CH + pays voisins)	CA → Emplacements nommés	art. 8
☐	Emplacement `Bureau-[Client]` créé si IP fixe disponible (optionnel, non référencé par les politiques)	CA → Emplacements nommés	

Politiques d'accès conditionnel

☐	Action	Portail / Chemin	nLPD
☐	CA-01 MFA tous utilisateurs : Application (après 7 j de rapport)	CA → Stratégies → CA-01	art. 8
☐	CA-02 Blocage auth héritée : Application (après 7 à 14 j de rapport et inventaire)	CA → Stratégies → CA-02	art. 8
☐	CA-09 MFA anti-hameçonnage administrateurs : Application (après 7 j de rapport et clés d'accès enregistrées)	CA → Stratégies → CA-09	art. 8

☐	Action	Portail / Chemin	nLPD
☐	CA-03 Filtrage géographique : Application (après 14 j de rapport)	CA → Stratégies → CA-03	art. 8
☐	CA-04 Token Protection : Rapport uniquement (Application après MVC Intune)	CA → Stratégies → CA-04	art. 8
☐	CA-05 Session limitée : Application	CA → Stratégies → CA-05	art. 8
☐	Prérequis CA-05 : SharePoint Admin → accès limité au web actif	admin.sharepoint.com → Stratégies → Contrôle d'accès → Appareils non gérés	art. 8
☐	CA-06 Hors horaires (expérimental, optionnel) : Rapport uniquement	CA → Stratégies → CA-06	art. 8
☐	CA-08 Appareil conforme : Rapport uniquement (Application après MVC Intune)	CA → Stratégies → CA-08	art. 8

SSPR

☐	Action	Portail / Chemin	nLPD
☐	SSPR activé pour `GRP-SSPR-Utilisateurs`	Entra ID → Réinit. MDP → Propriétés	art. 8
☐	2 méthodes configurées (Authenticator, E-mail ; téléphone transitoire, retrait SMS et voix Microsoft : 1er février 2027 pour les utilisateurs standards, 1er juillet 2027 pour les administrateurs généraux et externes, avec transition SSPR de 50 jours)	Entra ID → Réinit. MDP → Méthodes	art. 8
☐	Notifications utilisateur + admin activées	Entra ID → Réinit. MDP → Notifications	art. 8
☐	Écriture différée activée (si environnement hybride)	Entra ID → Réinit. MDP → Intégration locale	art. 8

Tests et validation

☐	Action	Portail / Chemin	nLPD
☐	T1 MFA déclenché sur compte utilisateur standard	Navigation privée → connexion	
☐	T2 Break-glass non bloqué par CA-01	Connexion bga1 et bga2	
☐	T3 Auth héritée bloquée (CA-02)	Client IMAP ou Outlook ancien	
☐	T4 Pays bloqué (CA-03)	VPN	
☐	T5 Session limitée SharePoint (CA-05)	Appareil non géré → SharePoint	
☐	T6 SSPR fonctionnel	https://aka.ms/sspr	
☐	T7 Journaux de connexion, colonnes CA visibles	entra.microsoft.com → Surveillance	
☐	T8 à T10 en Rapport (CA-04, CA-08, CA-06) ; T11 (CA-09) en Rapport puis en Application	Journaux de connexion	

Annexe C : Références nLPD, mesures techniques couvertes

Ce tableau peut être utilisé comme pièce justificative lors d'un audit PFPDT. Référence : **nLPD RS 235.1**, en vigueur depuis le 1er septembre 2023. Délai de notification d'une violation : **« dès que possible »** (pas 72 heures comme dans le RGPD européen). Autorité : **PFPDT** (pas la CNIL). Amende maximale : 250'000 CHF (personne physique).

Article nLPD	Obligation	Mesure technique déployée	Section
art. 8 al. 1	Mesures techniques adaptées au risque : contrôle des accès	MFA obligatoire via CA-01 (Authentication Strength niveau 1)	Partie 3
art. 8 al. 1	Fermer les vecteurs de contournement	Blocage authentification héritée (IMAP, POP3, SMTP) via CA-02	Partie 4
art. 8 al. 1	Réduction de la surface d'attaque géographique	Filtrage géographique : restrictions géographiques définies par l'entreprise via CA-03	Partie 5
art. 8 al. 1	Réduction du risque de rejeu de jetons de session	Token Protection (plateformes et applications compatibles) via CA-04	Partie 6
art. 8 al. 1	Contrôle des accès depuis appareils non gérés	Session restreinte SharePoint/OneDrive via CA-05	Partie 7
art. 8 al. 1	Détection des connexions inhabituelles (mesure complémentaire expérimentale)	Signalement des connexions hors horaires via CA-06 (Rapport)	Partie 8
art. 8 al. 1	Protection des comptes à privilèges	MFA anti-hameçonnage pour les administrateurs via CA-09	§3.2
art. 8 al. 1	Contrôle d'accès par état de sécurité de l'appareil	CA-08 Exiger un appareil conforme (Rapport, puis Application après MVC Intune)	Partie 9
art. 8 al. 1	Sécurité et traçabilité des opérations de gestion des identités	SSPR : réinitialisation auditée, 2 méthodes requises (le SSPR et ses journaux y contribuent, sans que la loi les prescrive nommément)	Partie 10
art. 8 al. 1	Authentification forte : résistance au phishing	FIDO2/Passkeys + Authentication Strength	Partie 1
art. 8 al. 1	Continuité d'accès sécurisée	Deux comptes break-glass (FIDO2, Administrateur général permanent, alerte de connexion)	§0.2
art. 8 al. 2	Éviter les violations de la sécurité des données (la loi ne prescrit pas de mesure nommée)	CAE (Continuous Access Evaluation) contribue à cette finalité : révocation en temps réel	Partie 3 (natif)
art. 24	Annonce des violations de la sécurité des données au PFPDT (et aux personnes concernées si nécessaire)	Les journaux de connexion Entra ID et les alertes du SIEM (par exemple règles UTMStack M14 et M3) facilitent la détection et la documentation d'un incident, mais l'obligation d'annonce reste organisationnelle	Parties 0, 8 et 11 (T7)

Annexe D : Tableau récapitulatif des politiques CA

Politique	Lic.	Cible	Condition	Action
CA-01-MFA-Tous-Utilisateurs	P1	Tous (sauf BG)	Toutes ressources	MFA niveau 1
CA-02-Blocage-Auth-Heritee	P1	Tous (sauf BG)	Auth héritée	Bloquer
CA-03-Blocage-Pays-Non-Autorises	P1	Tous (sauf BG)	Hors pays autorisés	Bloquer
CA-04-Token-Protection-Windows	P1	Pilote Direction + admins (sauf BG)	Exchange + SharePoint + Teams, Windows, applications natives	Session liée à l'appareil

Politique	Lic.	Cible	Condition	Action
CA-05-Session-Limitee	P1	Tous	SPO + appareils non gérés	Accès web uniquement
CA-06-Hors-Horaires-Experimental	P1	Tous (sauf BG)	Hors heures ouvrables (via Graph beta, expérimental)	Rapport uniquement ; blocage optionnel
CA-08-Exiger-Appareil-Conforme	P1	Tous (sauf BG)	Toutes ressources	Appareil conforme
CA-09-MFA-Phishing-Resistant-Administrateurs	P1	Rôles d'administration (sauf BG)	Toutes ressources	MFA anti-hameçonnage

INFO CA-04 et CA-08 restent en mode Rapport uniquement jusqu'au déploiement du MVC Intune + Defender. C'est dans le guide Intune + Defender qu'ils passent en Application. CA-06 est créée en mode Rapport ; son passage en Application est une décision du client après revue des journaux. Il n'existe pas de politique CA-07 dans le MVC.

Annexe E : Adaptations sectorielles

Les adaptations ci-dessous s'appliquent en supplément du MVC standard. Le reste du guide reste valide sans modification.

Secteur	Point de rupture	Adaptation recommandée
PME générique	Aucun	MVC tel quel. Aucune adaptation requise.
Fiduciaire itinérante	Connexions depuis les bureaux de clients (IP variables)	CA-03 : remplacer Bloquer par Exiger MFA. Les connexions hors Suisse sont autorisées après MFA.
Cabinet médical / Avocats	Confidentialité maximale exigée	CA-04 Token Protection : priorité haute, à déployer dès que Intune est actif. CA-01 : Authentication Strength niveau 2 (sans mot de passe) plutôt que niveau 1.
Agence de communication (nomades)	Collaborateurs en télétravail depuis l'étranger	CA-03 : mode MFA plutôt que blocage. Ajouter les pays de télétravail habituels à `Pays-Autorises-[Client]`.
Architecture / Ingénierie	Chantiers en Suisse et pays voisins	Vérifier que CH + DE + FR + IT sont dans `Pays-Autorises-[Client]`. Aucune autre adaptation requise.

Annexe F : Différences POC et production

Point	POC (test)	Production (recommandé)
Comptes break-glass	1 compte admin testé	2 comptes cloud-only, FIDO2, Administrateur général permanent, alerte de connexion
Méthodes MFA	Authenticator + SMS	Authenticator (priorité) + FIDO2 pour Direction et admins
CA-01 mode	Rapport 7 jours puis Application	Application après validation sur un groupe pilote
CA-03 mode	Rapport 14 jours puis Application	Application après revue des journaux de connexion
CA-04 Token Protection	Rapport (Intune non déployé)	Application après déploiement MVC Intune + Defender
SSPR écriture différée	Optionnelle (cloud-only)	Obligatoire en environnement hybride AD
Test break-glass	Manuel lors du déploiement	Tous les 90 jours et à chaque changement de personnel, documenté dans le registre de sécurité
Alertes connexions suspectes	Vérification manuelle hebdomadaire	Alertes automatisées (SIEM, MDCA ou Sentinel)